File hash analysis with the Pyramid of Pain

Scenario	An alert pointed at a suspicious file. I had to find out whether its hash was already known as malicious, and then place the indicators I found on the Pyramid of Pain, to see how much each one would hurt an attacker if I blocked it.
Has this file been identified as malicious?	Yes. I searched the SHA-256 hash on VirusTotal and a large number of security vendors flag it. The detections call it a trojan, with names such as Trojan.Flagpro and Fragtor. Flagpro is a malware family that has been linked to a threat group called BlackTech, so this is not a random piece of commodity malware.

Indicators on the pyramid

Level	Indicator found	How hard it is for the attacker to change	What it gives a defender
TTPs	Command and control	Tough. The attacker has to change the way they work.	The most lasting detection, because it follows the behavior and not one sample.
Tools	Input capture (recording what a user types)	Challenging. They need a new tool or a rewrite.	Blocking it forces real effort, but it needs good detection rules.
Network/host artifacts	HTTP requests used to talk to the attacker	Annoying. The traffic pattern has to be redesigned.	Good for detection rules that catch the same family even after small changes.
Domain names	org.misecure.com	Simple. A new domain costs little, but it has to be set up.	Blocks the current campaign until they switch.
IP addresses	207.148.109.242	Easy. A new server is quick to rent.	Useful in the short term, and it ages fast.
Hash values	MD5 287d612e29b71c90aa54947313810a25	Trivial. Changing one byte gives a new hash.	Catches only this exact file.

The pyramid uses the MD5 value from the lab sheet. The VirusTotal search itself was done with the SHA-256 hash.

What I took from it

The hash was the easiest thing to find and it is also the least useful to block. An attacker can recompile the same malware in a minute and the hash no longer matches. I now see why teams try to climb the pyramid. Detecting behavior, such as a program that records keystrokes and then calls home over HTTP, costs the attacker much more to avoid.

It also connects to the alert ticket case study, where the hash check was one of the steps that led to the escalation. Checking the hash is a good first step, but I would not stop there.